

CareBridge Canada - Astra Master Build Prompt

Version 2.1 · 24 September 2026 · Governs the from-scratch build · Supersedes v1.0 and v2.0

Use this document as the single governing implementation brief. Requirements below are proposed CareBridge product and release policies unless explicitly attributed to a source. They do not establish legal compliance, clinical approval, vendor authorization, or production readiness.

This brief governs building CareBridge Canada from scratch. The earlier chatgpt.site preview is a prototype. It serves only as a reference for design and content, and none of its code carries over unless it is reviewed and brought in deliberately (§0). Sections 1–21 keep their v1.0 numbers. Changed text is marked **UPDATED** and new sections **NEW**, with the version that introduced them.

Change log

Version	Date	Summary
1.0	Before 24 Sep 2026	Original governing brief: mission, gated sequence, privacy, security, identity, consent/audit, clinical governance, connectors, workflows, AI, design, accessibility, public site, reliability, MVP, architecture package, PHI go-live gate.
2.0	24 Sep 2026	Reconciles the role model (§6); fixes status-label and readiness rules (§2); separates the public site from the patient app (§16); makes emergency information inline (§8); adds resource and connector metadata rules (§9, §10), pricing, billing and entitlements (§22), engineering workflow (§23), roadmap (§24), definition of done (§25), prompt protocol (§26) and AGENTS.md.
2.1	24 Sep 2026	Turns the brief into a from-scratch build plan: the prototype becomes a reference (§0), the roadmap starts at Sprint 0 (§24), prototype findings become build requirements (§27), and the Sprint 0–2 prompts are rewritten (Appendix A). Adds practitioner identity and licence verification (§28).

0. Starting point: prototype as reference only **NEW v2.1**

CareBridge is built as a new application. The chatgpt.site preview (carebridge-canada.magicgeniecleaningse.chatgpt.site) showed the product idea and an honest demo posture. Nobody has seen its code, it has no test evidence, and it runs on a development preview host, so it isn't a foundation to build on.

From the prototype	Decision for the new build
Page list, navigation, copy, Liquid Glass look, demo banner, fictional personas, "0 live connections" honesty	Reuse as design and content reference. Rebuild the components properly against §14–15.
Readiness page and go-live gate list	Rebuild as one readiness data source (§2), backed by real evidence records.
Backend (tenancy, RBAC, audit, consoles) claimed in "Sprint 2"	Don't carry over. The code is unreviewed and has no test report. Rebuild in Sprints 1–2 with tests. Individual pieces may be imported only after a code review with passing tests.
Known defects: root serves the demo dashboard, emergency info only linked, non-standard status labels, missing resource and connector metadata, locked consoles with no MFA	Build them correctly from day one (§27).

From the prototype	Decision for the new build
Hosting on the chatgpt.site preview	Replace it with separate dev, staging and production environments (§23.4).

Version control is part of the build, not an optional extra. A healthcare platform needs a traceable history of every change, test run and approval as evidence for its gates. The private repository ericnosa/carebridge-canada (created, empty) is where the new build lives from Sprint 0.

Gate position at the start: Stage 0 (PIA readiness). No stage has exit evidence yet.

1. Mission and working mandate

Act with the combined rigor of a principal healthcare software architect, senior full-stack developer, DevSecOps engineer, cybersecurity specialist, privacy-by-design architect, clinical workflow specialist, UX/UI director, accessibility expert, and enterprise SaaS engineer. Do not claim professional credentials or substitute your output for accountable human review.

Build CAREBRIDGE CANADA: a premium healthcare access, navigation, orchestration, and care-continuity platform. Start with a controlled Regina, Saskatchewan pilot. Prepare for province-by-province expansion without enabling national clinical operations.

Primary positioning: "One place to find the right care."

Supporting positioning: "CareBridge connects patients, clinicians, and existing healthcare systems through one intelligent access and care-coordination layer."

Platform principle: "Keep the healthcare systems that already work. Connect the care around them."

CareBridge connects patients, professionals, clinics, organizations, and authorized government, EMR, pharmacy, lab, imaging, referral, and virtual-care infrastructure. It is a system of engagement and orchestration. Existing clinical systems should remain systems of record where appropriate. Do not build an EMR replacement or present CareBridge as another generic virtual-doctor app.

Where systems work: CONNECT. Where information is fragmented: ORCHESTRATE. Where patients need direction: NAVIGATE. Where care crosses systems: COORDINATE. Build new capability only where justified.

2. Execution contract **UPDATED v2.0**

v2.1: This is a from-scratch build (§0). Inspect the new project at the start of every run. Preserve reviewed, tested work and document gaps. If no repository or deployment access exists, state that limitation and generate reviewable specifications and code without claiming deployment.

Before implementing the full application, produce the architecture package in Section 19. Then implement sequential vertical slices with migrations, policies, tests, and operating evidence. Continue with authorized synthetic-data work when external approvals are unavailable; leave affected production functions disabled.

Use these evidence statuses: Proposed, Implemented, Tested, Human Review Required, Approved, Blocked. Screens, comments, checkboxes, mock responses, and passing unit tests alone cannot establish Approved status.

v2.0: The evidence statuses are the only labels allowed for requirements, gates and readiness items. Do not use In Progress, Under Review, Review required, Not Started or similar labels. "Under Review" in particular implies a reviewer is working on it, which is false. A console function that isn't built yet may say "Not implemented". Headlines must agree with the item statuses beneath them.

v2.0: Keep readiness in one data source. Show it at /readiness (public summary) and /governance/readiness (protected detail). Any other status page redirects to one of those two. Each

item records its owner, a separate reviewer, the evidence link, the review date and the next review date.

Maintain a requirements register mapping every requirement in this brief to its owner, stage, design artifact, implementation path, test, evidence, and outstanding approval. Record actual commands and outcomes. Never fabricate tests, integrations, approvals, clinicians, appointments, coverage checks, certification badges, partnerships, or SLA results.

v2.0: A TESTED claim must include the exact command that was run and its pass/fail counts. Once the repository exists, it must also include a link to the CI run on the pull request (\$23).

Default to a synthetic-data demonstration. Clearly label demonstration accounts and records. Demo mode is not a safe place to accept real PHI: disable public free-text medical submissions and real uploads, use controlled fixtures, and do not assume a banner or PHI detector prevents disclosure.

3. Mandatory gated sequence

This is CareBridge's engineering release policy, not a legally prescribed universal sequence. PIA, threat analysis, clinical safety, and vendor assessment must be revisited when designs change. Identify integration feasibility early; activate integrations only after their gates pass.

Stage	Deliverable and minimum exit evidence
0 - PIA readiness	Data inventory, organizational responsibilities, purposes, authority questions, processor inventory, data flows, retention proposals, and accountable privacy reviewer.
1 - TRA architecture	Trust boundaries, abuse cases, threat register, risk owners, mitigations, residual risks, and verification plan.
2 - PHI architecture	Storage boundaries, schema, data classification, key management, residency map, retention/deletion design, backup design, and data-isolation tests.
3 - IAM / RBAC / ABAC	Identity lifecycle, server-side policies, tenant isolation, credential restrictions, recovery controls, and positive/negative authorization tests.
4 - Consent / audit	Versioned purpose-specific permissions, legally authorized exception handling, durable audit capture, withdrawal enforcement, and failure-path tests.
5 - Clinical governance	Named accountable roles, protocol approval workflow, hazard register, escalation ownership, and safe synthetic routing fixtures. Production protocols need actual clinical approval.
6 - Core workflows	Tested end-to-end synthetic patient, clinician, organization, and support journeys.
7 - Integration architecture	Adapter contracts, sandbox tests, consent enforcement, provenance, reconciliation, failure isolation, and per-connector authorization evidence.
8 - Security validation	Authorization, application security, accessibility, load, clinical workflow, restore, and failure tests with evidence.
9 - Independent penetration testing	Scope and readiness package, completed independent assessment before live PHI, remediation evidence, and retesting. Readiness alone is insufficient.
10 - Closed Saskatchewan pilot	All applicable PHI gates passed before the first real participant; limited cohort, approved clinicians, monitoring, support, clinical oversight, rollback and stop criteria.
11 - Production operations / SLA	Measured pilot outcomes, sustainable SLOs, on-call operations, error budgets, incident learning, and separately approved contractual SLA.

Instrumentation, backup validation, incident readiness, and SLO measurement must exist before Stage 10. Stage 11 formalizes production commitments; it does not introduce monitoring for the first time.

Section 0 records the current stage position, and Section 24 maps sprints to stages.

4. Privacy foundation and PIA readiness **UPDATED v2.0**

Use Saskatchewan HIPA as a principal legal reference for the Saskatchewan design, subject to qualified review of applicability. Establish CareBridge's actual role for each relationship, including whether it acts as a trustee, service provider, or another applicable role. Have counsel identify any other applicable provincial/federal laws, professional obligations, contracts, and records requirements. Do not assume one legal model applies to every organization or future province.

Never automatically claim “HIPA compliant,” “HIPAA compliant,” “government approved,” “eHealth approved,” or “certified.” Distinguish implemented controls from independently reviewed or approved operational arrangements.

Create an access-controlled Privacy Impact Assessment workspace and PHI Data Flow Register. For each data category record: source, destination, purpose, collection/use/disclosure authority, sensitivity, patient/tenant scope, storage and processing location, processor/subprocessor, users/recipients, retention, destruction, authorization/consent requirements, safeguards, owner, and review date. Include queues, caches, logs, backups, AI providers, video services, notifications, support tooling, and remote support access.

v2.0: The processor inventory also lists the payment processor, the source-control host, the CI provider and email delivery, with each one's hosting region. Personal information that isn't health data still needs an entry: billing contacts and the pilot-interest form (§22) collect real names and emails even in the demo.

Inventory identity, health services numbers, coverage, symptoms, allergies, medications, diagnoses, intake, notes, prescriptions, referrals, results, imaging information, mental-health information, communications, and appointment history. Treat metadata as potentially sensitive. Collect only necessary fields and defer unnecessary medical history until needed.

Design patient access, amendment, delegated access, privacy complaint, disclosure review, breach response, legal hold, retention, and secure destruction workflows. Do not hard-code an invented universal retention period or promise deletion of legally retained clinical records. Preserve clinical corrections through amendments and provenance.

Prefer Canadian hosting and processing as a CareBridge design policy; document the actual region and subprocessors for every service. Do not claim Canadian hosting alone proves compliance or that every cross-border transfer is universally prohibited. Unresolved processing locations or contractual terms block the affected live PHI feature.

5. Security, data architecture, and threat model **UPDATED v2.0**

Define logical domains: Identity, Patient, Coverage, Clinical Record, Provider, Credential, Organization, Appointment, Referral, Consent, Audit, Integration Gateway, Notification, and Billing.

Logical separation does not require premature microservices. Select a modular monolith or separated services through an architecture decision record. If sharing a database, enforce tenant-scoped keys, database policies where appropriate, restricted service roles, clear schemas, and backend authorization. An unrestricted database credential behind visually separated screens is unacceptable.

Use typed contracts, versioned migrations, foreign keys, constraints, transactional state transitions, optimistic concurrency, idempotency keys, and an outbox or equivalent reliable event pattern. Separate public content from authenticated PHI systems. Separate development, test, staging, and production accounts, credentials, storage, keys, and datasets. Never copy production PHI into nonproduction.

Protect data in transit and at rest, including backups. Use managed key/secret storage, least-privilege key access, rotation/revocation procedures, and additional application encryption for high-risk identifiers where justified. Mask health services numbers by default; authorize and audit reveal actions. Never embed identifiers or PHI in public URLs, source bundles, analytics, ordinary application logs, crash reports, unsecured exports, or notification previews.

Use secure session cookies and server-side session enforcement; protect against CSRF, injection, XSS, SSRF, credential stuffing, insecure file access, and enumeration. Validate all inputs and outbound destinations. Configure CSP and appropriate security headers. Avoid browser persistence of PHI or bearer tokens; exclude PHI from service-worker/offline caches and shared HTTP caches. Clear sensitive client state on logout/account switching.

Uploads require authorization, size/type checks, quarantine, malware screening, safe rendering, private object storage, and short-lived scoped download authorization. Document print/download limitations: audit application-issued actions without falsely claiming to observe screenshots or every OS-level print action.

Threat register fields: risk_id, asset, threat, likelihood, impact, mitigation, owner, status, review_date, verification_evidence, residual_risk, and acceptance authority. Cover account takeover, credential theft, insider snooping, privilege escalation, broken access control, exfiltration, ransomware, API abuse, injection, XSS, hijacking, credential stuffing, malicious uploads, cloud misconfiguration, supply chain, lost devices, log/backup exposure, social engineering, AI leakage, and connector compromise.

Restrict platform/support administrators from routine clinical access. Separate infrastructure, credentialing, clinical, privacy, and security duties. Add access reviews, dormant-account removal, dependency scanning, secret scanning, software inventory, signed/reviewed releases where supported, and documented incident containment.

v2.0: The supply chain includes development tooling. AI coding agents, IDE extensions and plugins that can read the repository or run commands go in the tooling register (§23.6). Billing data is its own domain. It never joins clinical records, and nothing in it describes clinical activity.

6. Identity and authorization **UPDATED v2.0**

Patient identity: verified email; mobile verification where appropriate; passkey and MFA support; documented assurance level; risk-based step-up for sensitive access, record exports, proxy changes, and identifier changes. Contact verification and possession of a health card number do not independently prove identity. Account recovery must not bypass required assurance.

Providers and organization administrators require MFA. CareBridge privileged administrators require phishing-resistant MFA where technically practical; any exception needs explicit risk review. Suspend sessions and access promptly for offboarding, credential suspension, or compromised accounts.

v2.0: The MFA code can be built now and isn't blocked: WebAuthn/passkey and TOTP enrollment, verification, recovery codes, and a server-side recent-MFA check on privileged routes. Only provisioning real trusted staff waits for approval. The demo environment may seed one clearly labelled synthetic privileged account, and that account must not work outside the demo environment.

Canonical role model **UPDATED v2.0**

v1.0 listed profession-level roles, and the prototype used 13 coarser roles. The table below reconciles the two into the 16 roles the new build uses from its first migration. Profession becomes an ABAC attribute tied to a verified credential (§28), not a separate role.

Canonical role	Replaces (v1.0)	Scope and key restrictions
Patient	Patient	Own records only; self-service.

Canonical role	Replaces (v1.0)	Scope and key restrictions
Authorized Representative	Caregiver	Separate verified identity, documented authority, scope, expiry, revocation.
Healthcare Professional	Physician, NP, RN, Pharmacist, Mental Health Professional, Allied Health Professional	Profession attribute from a verified credential. Patient access only through an active care relationship.
Clinic Staff	Receptionist	Scheduling and front desk. No clinical notes by default.
Care Coordinator	Referral Coordinator	Referrals, tasks and follow-ups within care relationships.
Billing Staff	Billing Staff	Plans, subscriptions, invoices. No clinical data.
Clinic Administrator	Clinic Manager	Clinic configuration and staff invitations within their authority. Cannot bypass credentialing.
Organization Administrator	Organization Admin	Organization-wide configuration. Membership does not create a clinical relationship.
Medical Director	Medical Director	Approves clinical protocols. An approval needs this role plus a recorded approval.
Credentialing Officer	Credentialing Staff	Reviews provider credentials. Cannot approve their own.
Privacy Officer	Privacy Officer	PIA, disclosure review, access reviews, privacy complaints.
Security Officer	Security Administrator	Security configuration, incidents, access reviews.
Auditor	(new)	Read-only audit queries. The queries themselves are audited.
Integration Administrator	(new)	Connector configuration. No clinical read by default.
Support Agent	CareBridge Support	No routine clinical access. Break-glass not available.
System Administrator	Platform Administrator	Infrastructure only. No routine clinical access.

Combine RBAC with ABAC using organization, patient/care/encounter relationship, jurisdiction, current credential status, purpose, scope, consent or other authorized legal basis, and assurance level. Deny by default. Apply policies server-side to every API, query, search, file, export, background job, subscription, and connector operation. Never trust a client-supplied tenant identifier or role.

Doctors cannot browse every patient. Audit allowed and denied patient lookups without leaking unnecessary identity data. Tenant switching must reset context and permissions. Administrative organization membership does not create a clinical relationship.

Caregiver access requires a separate verified identity, documented authority, permitted scope, expiry/review, and revocation. Establish reviewed rules for minors, capacity, substitute decision makers, and restricted records before enabling those cohorts.

Break-glass access is a distinct server policy limited to authorized roles and permitted scenarios. Require reason, reauthentication, explicit warning, short scope/duration, enhanced audit, alerting, and post-access review. It must not silently bypass tenant, jurisdiction, or legal restrictions.

7. Consent and audit

Consent statuses: Granted, Declined, Withdrawn, Expired. Record subject, authorized decision maker, purpose, data scope, recipient, version, timestamp, evidence, expiry, and revocation. Separate care/data-sharing permissions from marketing and optional AI processing.

Do not reduce every lawful clinical use to an optional checkbox. Model consent and other reviewed legal authority separately. Withdrawal stops future consent-dependent actions, including queued exports and stale permissions; it cannot retract completed disclosures or automatically erase required records. Record exceptions and enforce scope at execution time.

Audit VIEW, CREATE, UPDATE, DOWNLOAD, PRINT, SHARE, EXPORT, DELETE, DISCLOSE, REFER, PRESCRIBE, SIGN, LOGIN, and BREAK_GLASS, plus denial and privileged configuration events. Record actor, role, patient reference, organization, resource reference, purpose, time, session/device context, result, correlation ID, and policy/protocol version where applicable. Minimize audit payloads and protect audit data as sensitive.

Use append-only capture and independently protected retention/immutable storage where available. Define who can query audit records and audit those queries. Monitor snooping patterns and investigate alerts. Explicitly test durable capture and audit outages; buffer safely or fail closed for affected sensitive actions under approved downtime policy. Do not silently drop events.

8. Clinical governance and jurisdiction **UPDATED v2.0**

Create a versioned protocol registry with effective dates, evidence, medical/nursing/relevant advisor approval, clinical quality review, owner, review deadline, rollback, and change history. Developers must not invent clinical thresholds. Unapproved protocols remain synthetic demonstration fixtures.

Trace routing to protocol version and approver. Maintain a clinical hazard register covering wrong-patient selection, stale information, delayed/misdirected referrals, missed critical results, inappropriate virtual care, and failed follow-up. Name the responsible care team for every clinical task.

v2.0: Tables to build: protocol_registry (version, effective dates, owner, approver, approval_status, review_date, change history) and clinical_hazards (hazard, cause, effect, mitigation, owner, status, review_date). Every row is labelled "Synthetic fixture: not clinically approved" until the Medical Director records an approval.

Jurisdiction rules must consider patient location at encounter time, provider authorization and scope, organization permissions, service type, age/capacity policy, and applicable restrictions. Do not equate coverage province with current care jurisdiction. Block unsupported clinical care with approved alternatives; public resources remain accessible.

Provide a clinically reviewed emergency pathway accessible without completing onboarding. Verify current official emergency/811 information before publication. Do not delay urgent help behind coverage checks, payment, identity completion, or AI questioning. The application must not imply continuous clinical monitoring unless actually staffed and contracted.

v2.0: Put a "Need help now?" panel inline on Get Care, My Care, Appointments and Messages, and on the public home page. It must be visible before the first step of any flow and without signing in. It lists 911 for emergencies, HealthLine 811 for Saskatchewan health advice, and the 9-8-8 Suicide Crisis Helpline. Check every number against its official source before publishing, and record the verifier and date. A link to the Resources page on its own is not enough.

9. Connector-first architecture **UPDATED v2.0**

Create "Integrations & Connected Systems" for organizations and a premium "Connected Healthcare" catalogue: "Connect the systems your organization already trusts."

Categories: Provincial Health Systems, EMRs, ePrescribing, Pharmacy, Referrals, Labs, Imaging, Virtual Care, Patient Records, Identity, Communications, Insurance/Benefits, Future Partners.

Research candidate connections for eHealth Saskatchewan, eHR Viewer, MySaskHealthRecord, authorized coverage verification, Accuro, Med Access, PrescribeIT, and appropriate referral/pharmacy/lab/imaging services. These names are candidates supplied in the product brief, not evidence of API availability or partnership. Verify current availability and authorization requirements through official sources. Do not invent endpoints, scrape patient portals, collect external patient passwords, or treat an official external link as a data integration.

Preserve the requested display labels: Connected, Available, Authorization Required, Government Authorization Required, Vendor Agreement Required, Requested, Coming Soon, Connection Issue. Internally separate capability, approval, and runtime state so “Available” cannot imply “authorized” or “healthy.” Planned entries default to Coming Soon or the verified applicable requirement. Connected requires actual authorization, configured credentials, validated scope, and a successful connection check. Show source, verification date, requirements, and last sync when applicable.

Use neutral icons unless logo use is authorized. Label speculative items “Planned integration - subject to technical and contractual authorization.” No partnership or government endorsement badges without evidence.

v2.0: Every connector card must show three things: the source used to check it, the verification date, and the exact planned-integration wording above. The prototype's catalogue had none of the three.

All healthcare data APIs go through CareBridge's backend Integration Gateway: authentication, least-privilege authorization, consent/authority validation, encryption, schema validation, transformation, rate limits, audit, observability, bounded retry, idempotency, circuit breakers, replay protection, signed webhooks, reconciliation, and error handling. Frontends must never call external healthcare data APIs directly. Reviewed redirects for authentication and direct encrypted video transport are separate flows; no vendor secrets may enter browser code.

Prefer supported HL7 FHIR, OAuth 2.0, SMART on FHIR, and applicable Canadian profiles including PS-CA. Pin supported versions and validate against actual vendor capabilities. Standards do not grant access rights. Isolate necessary vendor-specific adapters behind canonical contracts.

Each organization declares its Primary Clinical System. Define record ownership, read/write direction, permitted caching, retention, provenance, and conflict resolution per resource. Avoid duplicate charting. Preserve origin, author, timestamp, import time, verification status, and freshness. Patient matching requires multiple approved attributes and human handling of ambiguous matches; never silently merge based on one identifier.

Model asynchronous delivery honestly: queued, sent, acknowledged, rejected, reconciliation required. A successful HTTP response or simulated send does not prove clinical receipt. Connector failures must not stop unrelated services; show stale/unavailable data clearly and assign unresolved work to an owner.

10. Patient workflows **UPDATED v2.0**

Navigation: Home, Get Care, My Care, Appointments, Messages, Health Records, Health Coverage, Care Team, Healthcare Resources, Profile. GET CARE remains the dominant action.

v2.0: The authenticated patient app lives under /app, or on its own app subdomain, and is never served at the site root (§16). Signing out returns to the public home page and clears client state.

Onboarding: account → contact verification → appropriate identity verification → province → provincial coverage → minimal health profile → consent → accessibility preferences → dashboard. Provide relevant privacy notice before collection and obtain any required permission when that processing begins; a later consolidated consent screen cannot retroactively authorize earlier processing. Do not collect unnecessary identity documents or block public resources for uninsured people.

Coverage statuses: Not Added, Patient-Provided, Verification Pending, Verified Active, Unable to Verify, Coverage Issue, Inactive. “Verified Active” requires an authorized source, verification timestamp, and applicable freshness policy. A formatted number or uploaded card remains patient-provided. Coverage status is not proof that every service is insured; show reviewed service-specific fees where applicable.

Home: “How can we help today?” with a prominent glass GET CARE action and secondary Appointments, My Care, Messages, Records, Coverage, Care Team, Resources. Show coverage calmly.

Get Care: concern → progressive structured intake → approved safety screening → virtual suitability → routing → real available care options → appointment → consultation → care plan → follow-up. Use one-question focus, progress, accessible controls, back/edit, and secure recovery of drafts where justified. No universal RN-first rule.

Routing destinations: RN, NP, physician, pharmacist, mental-health professional, specialist, allied health, clinic, diagnostics, urgent care, emergency pathway. Eligibility and availability are real constraints. If no option exists, provide an approved actionable next step; never invent availability or booking confirmation.

My Care Journey shows completed and pending consultations, prescriptions, tests, referrals, and follow-ups using text plus icons. Every pending item needs status provenance, responsible team, next action, and escalation policy. Imported prescription status must not imply CareBridge prescribed it.

Healthcare Resources: official verified links for eHealth Saskatchewan, coverage services, Saskatchewan Account, MySaskHealthRecord, Saskatchewan Health Authority, HealthLine 811, mental-health and emergency resources. Label “Official External Service”; maintain URL, jurisdiction, verifier, last-reviewed date, and scheduled link review. Never imitate government login pages.

v2.0: Each resource record stores its URL, jurisdiction, verifier, last-reviewed date and next-review date, and the page shows the last-reviewed date. The prototype's page was missing coverage services, Saskatchewan Account, and mental-health and crisis resources (9-8-8 and SHA mental-health services).

11. Provider, organization, and staff workflows **UPDATED v2.1**

Provider onboarding: account → identity → profession → jurisdiction → regulatory college → licence/registration → specialty → liability coverage where applicable → organization affiliation → practice type → services → availability → privacy/security/virtual-care/workflow training → human credential review → approval.

“CareBridge Verified” is a platform review status, not regulatory endorsement. Define what was checked, source, date, limitations, expiry, renewal, and suspension. No self-issued badge or automated approval without the required human process.

Credential statuses: Unverified, Pending, Verified, Restricted, Suspended, Expired. Never display “Verified Healthcare Professional” unless actual verification evidence exists. **v2.1:** The full identity and licence verification pipeline, monitoring and tests are in §28.

Organizations: clinics, specialists, pharmacies, mental health, physiotherapy/allied health, diagnostics, virtual care, and community health; defer hospital/health-authority rollout. Hierarchy: Organization → Location → Department → Care Team → Staff.

Staff invitation: expiring single-use invite → identity → regulated credential checks where relevant → organization relationship → scoped role → training → activation. Organization administrators cannot bypass credential verification or grant privileges beyond their authority. Verify organization legitimacy and administrator authority.

Clinician dashboard: “Requires Your Attention.” Prioritize waiting patients, appointments, results to review, referrals, follow-ups, messages, and tasks. Secondary navigation: Patients, Schedule, Care Team, Credentials, Organization. Avoid vanity metrics.

Patient snapshot: visit reason/duration, symptoms, allergies, medications, conditions, relevant recent encounters/results, active referrals, preferred pharmacy, coverage, and patient goals. Clearly distinguish Patient Reported, Imported, Clinician Reviewed, unavailable, and stale information. Preserve uncertainty; do not relabel imported data as verified automatically.

Organization dashboard: “Today’s Operations”; scheduled patients, waiting, available providers, no-shows, pending referrals, results, credential warnings, followed by clear solid data panels. Restrict each metric to authorized organizational scope.

12. Consultation, referrals, and communications

Support approved secure video, audio fallback, messaging, images/documents, clinical notes, care plans, and referrals. No recording by default. Assess the actual video provider, metadata processing, accessibility, consent, security, and fallback arrangements before activation.

Use safe scheduling with transactional slot reservation, conflict checks, explicit timezone handling, cancellation/rescheduling, wait states, and idempotent booking. Label all demo appointments. Saskatchewan uses America/Regina time year-round (no daylight saving).

“Escalate Care” routes to in-person, same-day, diagnostics, urgent assessment, emergency, or other appropriate providers. Record handoff, receiving destination, acknowledgement, ownership, and next steps. Never imply a transfer occurred when only a recommendation or external link was provided.

Referral states: Draft, Sent, Delivered, Acknowledged, Under Review, Additional Information Needed, Accepted, Appointment Scheduling, Scheduled, Completed, Report Returned, Closed, Declined. Enforce valid transitions, role authority, timestamps, evidence, audit, and overdue escalation. Define reviewed cancellation/withdrawal paths without deleting history.

Keep clinical content in secure messaging or authorized clinical systems. Ordinary SMS/email should use generic notifications such as “You have a new secure CareBridge update.” Prevent PHI in subjects, previews, link parameters, tracking pixels, and notification logs. Secure message links require authorization. Publish actual response-time expectations and emergency instructions approved by the clinical team.

Critical result handling requires explicit accountable human review, acknowledgement, escalation, and downtime procedures. Do not let an AI or a generic unread-message indicator substitute for that workflow.

13. AI gateway

AI may assist with structured intake, summaries, navigation, appointment administration, administrative/referral drafts, plain-language explanations, and task prioritization within approved scope.

AI must not autonomously diagnose, prescribe, approve treatment, release critical results, or override clinicians. Clinical drafts require review before signing or sending. Separate approved clinical routing logic from generative wording and test for unsafe omission, hallucination, bias, and missed escalation.

Route AI processing through a controlled gateway with authorization, minimum necessary context, tenant isolation, approved model/vendor/version, region/retention assessment, contractual review, evaluation, audit, timeout, output validation, and fallback. Do not send PHI to a model until its processing terms and applicable authority are approved. “No training” alone does not resolve retention, residency, support access, or subprocessors.

Treat user input, retrieved records, and external documents as untrusted data. Defend against prompt injection and tool misuse; the model cannot grant permissions or trigger unapproved clinical actions. Avoid PHI in general prompt traces or evaluation services. Attribute summaries to source records and visibly label drafts and uncertainty.

If AI fails, manual intake, approved routing, scheduling, messaging, and care coordination must remain usable.

14. Premium design and Liquid Glass system

Create an original calm, trustworthy, modern, human, Canadian healthcare identity. Avoid generic SaaS templates, neon, aggressive gradients, cartoon medicine, crypto-style dashboards, and decorative AI imagery.

Palette: deep navy, clean white, warm off-white, cool neutral grey, soft medical blue, subtle teal; muted gold only as a selective decorative accent. Define accessible semantic tokens for text, surface, border, focus, status, overlay, motion, spacing, radius, typography, and elevation. Color candidates are not approved until tested against actual composites.

Use readable typography, clear numerals, comfortable line height, mobile legibility, confident public headings, and compact but readable dashboard hierarchy. Use self-hosted or privacy-reviewed fonts. Build responsive patient, clinician, organization, and admin layouts.

Implement reusable React/TypeScript components, or equivalent components in the established stack: GlassSurface, GlassCard, GlassNav, GlassModal, GlassStatus. Expose controlled intensity, interactive, motion, and solid-surface options. “Liquid Glass” describes the visual system; do not assume a specific library exists. Verify any dependency’s provenance, maintenance, licence, accessibility, and bundle cost before adopting it.

Level	Use	Treatment
1 - Subtle	Forms, tables, notes, medication lists, results, critical information	Solid or nearly opaque surfaces; no content distortion.
2 - Standard	Navigation, dashboard summaries, provider cards, status panels, pricing cards	Restrained blur, clear borders, subtle elevation.
3 - Feature	Public hero, selected floating actions, care journey, connector showcase	Carefully bounded reflection/refraction-like decoration; stable legible content.

Use optional background diffusion, soft edge reflection, light-response highlights, gentle spring motion, and very subtle pointer parallax on suitable surfaces. Keep decoration in noninteractive layers behind content. Never displace text, form controls, focus outlines, or clinical values. Do not render PHI to decorative canvases, external visual services, or shaders.

Prefer CSS; use JavaScript only for bounded enhancement. Use transforms/opacity where appropriate; throttle pointer updates through requestAnimationFrame without per-frame React state churn. Stop when idle, offscreen, or document-hidden. Use IntersectionObserver, small repaint areas, coarse-pointer fallbacks, and clean up listeners. No continuous animation of every glass component, full-page blur stack, or heavy WebGL dependency solely for decoration.

Provide prefers-reduced-motion handling, forced-colors support, a manual Reduce Effects preference, and an opaque fallback when backdrop-filter is unavailable or unsuitable. Disable parallax for reduced motion. Effects cannot gate access to any action or information.

Micro-interactions: subtle button compression, elevation, modal transitions, skeletons, progress, and status confirmation. No healthcare gamification. Never animate an unverified connection into apparent success.

Connector cards show name/icon, factual description, capability, requirements, authorization, runtime state, and next action. Connected: restrained green; authorization: amber; issue: muted red; planned: grey. Always include text/icon meaning, not color alone.

15. Accessibility and performance gates

Target WCAG 2.2 AA across public and authenticated journeys. Test keyboard navigation, screen readers, logical focus order, visible/unobscured focus, modal focus containment/return, labels, validation, status announcements, password manager/paste support, accessible authentication, text resizing, and reflow. Avoid unnecessary cognitive tests and repeated data entry.

For applicable elements, satisfy WCAG contrast requirements: normal text 4.5:1; large text 3:1; non-text controls and meaningful graphics 3:1. Test glass against worst-case backgrounds. Meet target-size criteria and applicable exceptions; use 44×44 CSS pixels as CareBridge's preferred touch-target design target, not as a claim about the WCAG AA minimum.

Use automated checks plus manual review of critical tasks. No WCAG compliance badge based solely on automated scoring. Ensure nonvisual users receive equivalent connector states, care progress, and urgent instructions.

Proposed engineering budgets, to be validated on declared devices/network profiles: route-level LCP ≤ 2.5 seconds, INP ≤ 200 milliseconds, CLS ≤ 0.1 at the 75th percentile where field measurement is available. Establish initial JavaScript budgets after stack inspection, prevent unreviewed regressions, and report lab versus field evidence separately. These are engineering targets, not measured claims. Glass must be removable without layout or workflow breakage.

Do not use session replay, advertising trackers, PHI-bearing analytics, or unreviewed third-party scripts in authenticated healthcare areas. Keep performance telemetry free of PHI and validate payloads.

16. Public website **UPDATED v2.0**

Pages: Home, How CareBridge Works, For Patients, For Healthcare Professionals, For Clinics, For Organizations, Integrations, Security & Privacy, Healthcare Resources, **Pricing**, About, Contact, Help Centre.

v2.0: The public home page is served at /. The prototype's root showed the signed-in demo dashboard ("Welcome back, Alex"); the new build must not. The demo profile is reached only through an explicit "Explore the demo sandbox" action. Public pages don't need an account.

Home headline: "Healthcare shouldn't start with guessing where to go."

Supporting copy: "CareBridge helps Canadians find appropriate care, connect with verified healthcare professionals, and stay supported through what happens next." Use this as intended launch copy only when those capabilities exist. Before launch, qualify with "CareBridge is being built to..." and disclose pilot availability.

Primary CTA: Get Care. Secondary: For Healthcare Professionals. Third: For Organizations. Before live care is available, Get Care must clearly lead to an honest pilot-availability or synthetic demo state; no collection of real symptoms through an unapproved waitlist.

Explain one connected care journey: Access → Navigate → Connect → Coordinate → Follow Up.

Trust themes: secure access, reviewed professionals, privacy-first architecture, existing-system connections, continuity, Canadian-first design. Every published factual claim needs evidence. Do not invent testimonials, numbers, affiliations, certifications, or verified practitioners.

Integration headline: "Keep the systems that work." Explain that CareBridge is designed to connect existing infrastructure. Distinguish planned capabilities from working integrations.

Security page: understandable explanations of actual encryption, identity, MFA, access controls, audit, consent, secure integrations, incident response, and privacy practices. Publish only implemented/reviewed claims, without exposing secrets or sensitive infrastructure detail.

Pricing page: follows §22.3.

17. Reliability and operations

Propose an internal 99.9% monthly availability SLO for core services. Define each SLI, numerator/denominator or time-based calculation, observation window, maintenance treatment, dependencies, error budget, owner, and alert policy. For illustration, a 30-day time-based window permits $30 \times 24 \times 60 \times 0.001 = 43.2$ minutes outside the objective. This is not a public SLA or achieved result.

Instrument authentication, patient/provider access, Get Care, appointments, messages, referral workflows, and Integration Gateway before the pilot. Measure successful user journeys, latency, queue age, failed delivery, data freshness, and connector health. Monitor internal service health and external dependency impact separately; do not hide user-visible failures by relabeling them external.

Define approved RTO and RPO per service rather than inventing commitments. Implement encrypted backups, isolated recovery access, point-in-time recovery where appropriate, persistent queues, multiple instances where justified, restore exercises, failover tests, incident runbooks, and recovery reconciliation. Test that withdrawals, suspended accounts, and deletion/retention rules survive restoration.

AI and analytics failure must not block core workflows. Isolate failed connectors. Video failure must invoke an approved clinical fallback. Define safe downtime behavior for identity, consent, and audit outages; graceful degradation must not bypass authorization or silently lose clinical work.

Set staffed support/on-call coverage, incident severity, escalation owners, communication procedures, breach-review responsibilities, rollback, pilot pause criteria, and change management. Do not imply 24/7 care solely because infrastructure runs continuously.

18. MVP scope and verification **UPDATED v2.0**

Retain in the MVP backlog: patient signup/identity/coverage/profile, Get Care/intake/routing, provider discovery, provider/organization/staff onboarding, scheduling, approved virtual care, care plans, referrals, concierge journey, secure messages, official resources, connector catalogue, consent, audit, RBAC/ABAC, **and organization subscriptions with entitlements (§22)**. Deliver these in controlled slices. Catalogue and sandbox adapters may precede live connectors; unavailable clinical capabilities remain visibly unavailable.

Defer national hospital integration, EMR replacement, autonomous diagnosis, a custom national prescribing network, wholesale provincial record replication, every specialty, complex insurance adjudication, patient-paid services, and national rollout. Integrated prescribing is activated only through an approved workflow and authorized infrastructure.

Test unit/domain behavior, integrations, cross-tenant isolation, RBAC/ABAC, credential expiry, consent withdrawal races, proxy access, emergency overrides, audit completeness, upload safety, sessions, APIs, exports, accessibility, load, backups, connector failure, AI fallback, scheduling concurrency, referral ownership, and clinically approved safety cases.

Include negative tests: a provider cannot open an unrelated patient; support cannot view clinical records; switching organizations cannot reuse earlier permissions; expired credentials prevent practice; patient-provided coverage cannot become verified without evidence; a withdrawn consent blocks queued disclosure; a duplicate callback cannot duplicate a booking/referral; missing approvals prevent PHI activation; disabled visual effects preserve all actions.

v2.0 additional negative tests:

- Clinic A cannot read or book Clinic B slots, appointments or any other data.
- Two concurrent bookings of one slot: exactly one succeeds. The same idempotency key sent twice creates one booking.
- A patient cannot view another patient's appointment (IDOR/BOLA).

- A privileged user without a recent verified MFA session is denied every console.
- The synthetic demo privileged account cannot sign in outside the demo environment.
- A Credentialing Officer cannot approve their own credential.
- No entitlement, seat limit or subscription status blocks a patient's access to emergency information, resources, Get Care, existing appointments or their own records.
- A lapsed organization subscription deletes nothing and doesn't cut off an active care relationship without a handoff.
- Invoice and billing output contains no clinical fields, patient names or diagnoses.
- With PAYMENTS_ENABLED=false on the server, no checkout or charge path can run.

Prepare independent penetration testing of authentication, authorization, patient/tenant isolation, administrators, APIs, files, sessions, privilege escalation, business logic, and gateway. Complete and retest findings before live PHI. Critical/high unresolved security findings block release; lower residual risks require accountable documented acceptance. Passing a self-run scanner is not independent penetration testing.

19. Required architecture package before full implementation **UPDATED v2.0**

Produce all of the following as versioned project artifacts. **v2.0:** Store them as short files in the repository under /docs/architecture. Each stays Proposed until a named reviewer marks it otherwise.

1. System architecture, deployment boundaries, and architecture decisions.
2. PHI data-flow diagrams and register.
3. Database schema, migrations strategy, ownership, retention, provenance.
4. RBAC matrix including denied and delegated actions (use the canonical roles in §6).
5. ABAC rules with executable policy test cases.
6. Consent and lawful-authority architecture.
7. Audit event model, storage, review, and outage behavior.
8. Threat/risk model and clinical hazard register.
9. PIA readiness map, processor register, unresolved legal questions.
10. Jurisdiction engine and supported cohort restrictions.
11. Connector catalogue, gateway contracts, authorization evidence model.
12. Patient flow, including unavailable care and emergency access.
13. Provider flow and credential lifecycle.
14. Organization/staff flow and separation of duties.
15. Admin/support/privacy/security flow.
16. Clinical routing, escalation, results, and referral ownership flow.
17. Liquid Glass design system with solid/reduced-motion examples.
18. Design tokens with contrast validation.
19. Accessible component library and state specifications.
20. Security architecture and PHI activation mechanism.
21. SLI/SLO architecture, DR plan, incident/runbook framework.
22. Prioritized MVP backlog with dependencies and acceptance criteria.
23. Test strategy, test-data approach, and independent assessment scope.
24. Go-live evidence register and closed-pilot plan.
25. **v2.0:** Pricing, billing and entitlement model, including the patient-access guarantees in §22.5.

26. **v2.0:** Repository, CI, environment and tooling register (\$23).

27. **v2.1:** Credentialing policy, verification pipeline and monitoring design (\$28).

For each stage report what is implemented, tested, awaiting human review, blocked, and next. If essential information is missing, identify the precise decision and continue unaffected synthetic work. Do not substitute a polished marketing site for this package.

20. Enforced PHI go-live gate **UPDATED v2.0**

Default server-side PHI ingestion, clinical activation, and external PHI egress to disabled. Separate demo and production credentials and infrastructure. UI switches and client feature flags cannot authorize PHI.

Design an independently controlled deployment/activation policy requiring a reviewed, environment-specific approval record tied to release version, scope, evidence, approvers, and dates. Keep approver credentials outside the application developer's routine access. Add expiry/review triggers and rollback. Approval applies only to the cohort, jurisdiction, processors, and connectors reviewed; material changes trigger reassessment.

Require documented evidence for:

- PIA completed/reviewed as appropriate and privacy responsibilities assigned.
- TRA completed with residual risk disposition.
- Clinical governance and protocols approved.
- Security architecture reviewed.
- RBAC/ABAC, tenant isolation, consent, and audit tested.
- Successful backup restore and recovery reconciliation.
- Incident/breach process exercised.
- Privacy notices, retention, access/amendment processes reviewed.
- Vendor/subprocessor reviews and required agreements completed.
- Each enabled connector technically and contractually authorized.
- Independent penetration testing completed; required remediation retested.
- Clinical safety, accessibility, and operational readiness reviewed.
- Applicable legal review and required contracts completed.
- Accountable human sign-off recorded.

The same gate applies before a closed pilot receives real PHI. Synthetic testing may continue while gates are incomplete. Astra cannot sign on behalf of privacy, security, legal, clinical, or operational reviewers, nor auto-complete their approval records.

Commercial activation gate **NEW v2.0**

This gate is separate from the PHI gate and works the same way. `PAYMENTS_ENABLED` stays false on the server, with no live checkout, trials or charges, until there is documented evidence of all of the following:

- Health-law counsel has reviewed the pricing model against the Canada Health Act and Saskatchewan rules, including confirmation that patients are never charged for insured services or for access to them.
- The payment processor has had a vendor review, has a PIA processor entry, and has its hosting region recorded.
- An accountant has confirmed tax registration and treatment (GST and Saskatchewan PST).
- Clinic and organization terms of service, cancellation and refund policy, and privacy notice have been reviewed.

- The PHI go-live gate has passed for any paid tier that involves real clinical use.
- Accountable human sign-off has been recorded.

21. Final delivery behavior **UPDATED v2.0**

Deliver a coherent implementation with clear repository paths, runnable setup instructions, migrations, synthetic fixtures, configuration templates without secrets, test results, operating documentation, known limitations, and an evidence-based readiness report. **v2.0:** Delivery happens through pull requests to the private repository (§23), with CI results attached.

Never describe the result as production-ready solely because code builds or screens render. State exactly which capabilities work, which are simulations, which need external access, and which require human approval.

The patient experience must remain simple: “I need healthcare” → “Tell us what you need” → “Here are appropriate care options” → “You’re connected” → “Here’s what happens next.”

Prioritize patient safety, privacy, security, clinical governance, accessibility, interoperability, and continuity above visual effects. Deliver premium public pages, navigation, care journey, and connector surfaces while keeping clinical records, notes, medications, and results clear and stable.

Begin with project inspection and the architecture package. Then implement the first safe, synthetic-data slice, following the gates above. **v2.0:** The current starting point is \$0, and the order of work is §24.

22. Pricing, billing, and entitlements **NEW v2.0**

22.1 Principle: organizations pay, patients never do

CareBridge charges practitioners, clinics and organizations. Patients use CareBridge free of charge. The reasons:

- The Canada Health Act bars charging insured persons for medically necessary insured services. Health Canada's position is that access to insured services can't depend on paying a membership fee, and it asks provinces to investigate such charges.
- Virtual platforms are in scope. Alberta's review of membership clinics flagged one that required payment to use an online platform delivering both insured and uninsured services.
- In Saskatchewan, physician virtual care fee codes are permanent insured services, so a patient paywall in front of Get Care would put partner clinics at risk.
- §8 already requires that urgent help never waits behind payment.

This is a product policy grounded in public sources, not a legal opinion. The commercial activation gate (§20) requires review by counsel.

22.2 Tiers (proposed pilot pricing, not yet available)

Tier	Audience	Proposed price (CAD)	Includes (only as each item is implemented)
Patient	Everyone	Free, always	Get Care navigation, emergency information, resources, booking, care journey, own records, secure messages with their care team.
Independent Practitioner	Solo NP, allied health, mental-health professional	\$49 / month	Verified profile, scheduling, secure messaging, care plans.
Clinic	Clinics with 2–10 providers	\$249 / month including 2 providers; +\$39 / month per additional provider	Staff roles, referral tracking, care coordination, audit reports.
Organization	Multi-location groups, community health centres, pharmacy groups	Custom	Multi-clinic tenancy, SSO, connectors where technically and contractually authorized, privacy/security support, separately contracted SLA.

Prices are placeholders to test with pilot clinics. Annual billing, pilot discounts and non-profit pricing are open decisions.

22.3 Pricing page rules

- Use the existing Glass components (Level 2 surfaces). No new libraries.
- Every price carries the label "Proposed pilot pricing: not yet available". "Patient: Free, always" is the first card.
- CTAs are "Explore the demo sandbox" and "Join the Saskatchewan pilot". There is no checkout, no free trial and no "Start trial" wording.
- The pilot-interest form collects name, organization, role and email only, with no health information. This is real personal information: add a privacy notice, retention period, spam protection, a PIA entry and an audit event before enabling it. Until then, use a disabled form or a contact email.
- Feature lists name only implemented items, or items labelled "Planned". Connectors say "where technically and contractually authorized".
- No SLA, uptime, certification, compliance, testimonial or competitor claims.

22.4 Billing domain

Tables: plans, plan_prices (versioned, CAD), subscriptions (organization_id, status, period, seats), entitlements, invoices, invoice_lines, payment_events (signature-verified, idempotent webhooks) and billing_contacts. All of them are tenant-scoped, authorized server-side (Billing Staff, Organization Administrator) and audited. PAYMENTS_ENABLED is false in every environment until the commercial gate passes. Card data never touches CareBridge servers: use processor-hosted payment fields so that PCI scope stays minimal.

22.5 Entitlement rules (each one needs a test)

- Entitlements are evaluated on the server. They may limit staff seats, organization features and integrations.
- Nothing about entitlements ever limits patient access to emergency information, resources, Get Care navigation, existing appointments or the patient's own records.
- If a subscription lapses or is downgraded, nothing is deleted. Existing appointments and care tasks continue or get an explicit handoff, authorized users keep read access to clinical records under the retention rules, and patients are shown alternatives.

- A seat limit can't remove a clinician from an active care relationship unless a handoff task is created.
- Downgrades take effect at the end of the billing period, never mid-consultation.

22.6 Invoices and billing data

Invoice lines describe only the plan, seats and billing period. They never include clinical descriptions, patient names, diagnoses, visit types or per-patient counts. The payment processor receives only the billing contact and organization details.

22.7 Patient-paid uninsured services (deferred)

Forms, notes and other uninsured extras stay out of scope. Before any of them is added, counsel must review it. Under the College of Physicians and Surgeons of Saskatchewan's uninsured-services policy, fees must be disclosed before the service is provided. Uninsured extras must never be bundled with access to insured care, and there are no patient membership fees.

23. Engineering workflow and toolchain NEW v2.0, UPDATED v2.1

23.1 Project setup (Sprint 0)

1. Choose the stack through an architecture decision record (ADR-001), covering language, framework, database, hosting region and identity approach. Prefer managed services hosted in Canada, and record where each one processes data (§4).
2. Initialize the private repository ericnosa/carebridge-canada with the required files (§23.3) before any feature code.
3. Set up the dev and staging environments and CI. Production is provisioned but has PHI and payments disabled.
4. Write the §19 architecture package as short files, and get a human review of the Stage 0–2 items before the Sprint 1 code starts.

23.2 Repository protections

- 2FA on every account with access. Collaborators get the least role they need.
- Protect main: pull request required, CI checks required, no force pushes, no deletion.
- Secret scanning with push protection, Dependabot alerts and security updates, and private vulnerability reporting (availability may depend on the GitHub plan).

23.3 Required repository files

File	Purpose
AGENTS.md (and .github/copilot-instructions.md)	Standing rules that coding agents read on every session (Appendix B). Sprint prompts then carry only the change.
SECURITY.md	Private vulnerability reporting. States that the build uses synthetic data only and has no production PHI.
.gitignore, .env.example	.env*, dependency folders, build output, keys and logs are excluded. The example file has blank values.
docs/architecture/	The §19 package, including this brief. Short files, marked Proposed until reviewed.
.github/workflows/ci.yml	Install, lint, typecheck, test and security scan on every PR and on pushes to main. Least-privilege permissions.
.github/dependabot.yml	Weekly updates for the package ecosystem and GitHub Actions.
.github/pull_request_template.md	Checklist: tests, tenant isolation, audit events, no PHI, no claims, and the report format.

23.4 Environments

There are three environments: development (synthetic), staging (synthetic, production-like) and production (PHI only after the \$20 gate). Each has its own credentials, database, keys and storage. The PHI and payment flags are set per environment on the server.

23.5 Working method

- One sprint run = one branch = one pull request, and CI must pass before merge.
- Foundation work (identity, tenancy, RBAC, audit, credentialing) is done by a single agent working in sequence. Parallel agents are used only for independent UI work once the foundation is in place.
- Before any agent run, confirm the open project folder is CareBridge. On 24 Sep 2026 a setup prompt was started in the wrong project.
- Never paste secret values into any chat or prompt. Report only the file and line where a secret was found.
- Put STOP checkpoints before irreversible steps: pushes, migrations on shared data, and deletions.

23.6 Tooling register and plugin policy

Only install tools and plugins from a verified publisher with a clear source. For each one, record the publisher, its access (repository read/write, command execution, network), its purpose and the approval date. State as of 24 Sep 2026:

Tool	Publisher verified?	Decision
Codex Security	Yes (OpenAI)	Install. Run a read-only scan every sprint and triage findings into the threat register. It does not count as a penetration test.
Codex Advisor	No	Keep only if the publisher checks out (described as read-only).
Codex Browser Recorder	No	Keep only if the publisher checks out. Record demo accounts only.
Codex Dev Workflows	No	Optional. Disable if not used.
Adaptive Codex Orchestrator	No	Disable while foundation work is in progress.
Empire LLM for Codex	No	Disable. Model routing can send code to unreviewed providers.
GitHub Copilot (VS Code, Agent mode)	Yes (GitHub)	Allowed for edits in the local project folder. The web chat can't see local files.

24. Build roadmap from scratch NEW v2.0, UPDATED v2.1

Run each sprint's parts one at a time, and start the next part only after the previous one reports TESTED with evidence. The prompts for Sprints 0-2 are in Appendix A. Later sprints use the same template (§26).

Sprint	Scope	Stage	Exit evidence
S0	Project setup, stack ADR, environments, CI, AGENTS.md, §19 architecture package.	0-2	Repo and CI green; Stage 0-2 documents reviewed by a human.

Sprint	Scope	Stage	Exit evidence
S1	Identity, MFA, organizations/clinics/memberships, 16 roles, RBAC + ABAC deny-by-default, append-only audit.	3-4	Cross-tenant, IDOR, escalation, MFA and audit tests pass.
S2	Practitioner verification and credentialing (\$28), care relationships, consent and processing authority.	3-4	\$28.7 tests pass; no unverified practitioner can reach a patient.
S3	Clinical governance registries, readiness data source, public website with emergency panel, resources, connector catalogue.	5-6	Emergency panel unauthenticated on every route; one readiness source.
S4	Patient app under /app: onboarding (synthetic), coverage statuses, profile, care team.	6	Onboarding and coverage-status tests; accessibility spot check.
S5	Scheduling slice.	6	Concurrency, idempotency, tenancy and audit tests.
S6	Get Care structured intake, synthetic protocol routing, emergency pathway. No free text.	5-6	Routing traced to protocol version; red-flag escalation tests.
S7	Provider, organization and staff dashboards; staff invitation.	6	Separation-of-duties tests.
S8	Referral state machine, synthetic secure messaging, generic notifications, critical-result skeleton.	6	Invalid-transition and no-PHI-in-notification tests.
S9	Pricing page, billing domain, entitlements (\$22).	6	Entitlement, invoice and payments-disabled tests.
S10	Integration Gateway plus one synthetic FHIR sandbox adapter.	7	Contract, failure-isolation and reconciliation tests.
S11	AI gateway, off by default, with manual fallback.	6-7	Injection, fallback and no-PHI-egress tests.
S12	Validation: WCAG 2.2 AA manual review, performance budgets, security tests, restore exercise, incident drill.	8	Evidence recorded in the readiness register.

External workstream (human-owned, runs in parallel)

Item	Owner to appoint	Unblocks
PIA and privacy role determination	Privacy counsel / Privacy Officer	Stage 0; PHI gate
Threat and risk assessment	Security Officer / external assessor	Stage 1; PHI gate
Protocol approval and hazard review	Medical Director	Stage 5; live routing
Credentialing policy, Credentialing Officer appointment, regulator permissions for register use (§28)	Medical Director + counsel	Real practitioner onboarding
Vendor and processor reviews (hosting, identity verification, video, email, payments, AI)	Privacy + Security Officers	PHI and commercial gates
Pricing and Canada Health Act review; terms of service	Health-law counsel	Commercial gate
Tax registration and treatment	Accountant	Commercial gate
Cyber and professional liability insurance	Founder / broker	Pilot
Independent penetration test	External firm	Stage 9
Pilot clinic recruitment and closed-pilot plan	Founder / Medical Director	Stage 10

25. Definition of done for every slice NEW v2.0

- Migrations, constraints and foreign keys are in place, and state transitions are transactional.
- Authorization is server-side and deny-by-default, including ABAC conditions and care-relationship checks.
- There is a tenant-isolation test, and negative tests for each new permission.
- Sensitive actions write audit events, and a test proves it.
- Synthetic fixtures are labelled, and no real personal or health data is present.
- Emergency information and patient access guarantees are unaffected.
- Changed screens pass a keyboard, focus and screen-reader spot check, and still work with glass disabled.
- There are no compliance, certification or production-ready claims.
- The requirements register and the relevant /docs/architecture file are updated.
- CI is green on the pull request, and the report includes the command and pass/fail counts.
- The status is set to Tested. Only a named human reviewer can set Approved.

26. Prompt protocol for Astra runs NEW v2.0

- Standing rules live in AGENTS.md (Appendix B). Sprint prompts contain only what's new, so they cost fewer credits.
- Split large work into runs that can each finish within one session. A run that runs out of credits halfway leaves broken work behind.
- Each run lists its own tests next to the work they cover.
- Put STOP checkpoints before irreversible actions.
- Every run ends with this report and nothing else:

COMPLETED – items implemented (files/paths)
 TESTED – exact command + pass/fail counts (+ CI link once the repo exists)
 BLOCKED – items needing external legal/privacy/clinical/vendor approval, and why
 NEXT – maximum 3 implementation actions

After each run, paste the TESTED section in for an independent review, and only start the next run once it passes. The work shouldn't be graded by the same agent that produced it.

27. Lessons from the prototype, built in from day one **NEW**

v2.0, UPDATED v2.1

#	Prototype finding (reviews of 24 Sep 2026)	Requirement in the new build	Sprint
1	Get Care's "Need help now?" box only linked to Resources.	Inline 911, 811 and 9-8-8 on every care route (§8).	S3
2	/ served the signed-in demo dashboard.	Public home at /, app under /app (§16).	S3-S4
3	Three overlapping readiness pages with non-standard labels.	One readiness source, evidence statuses only (§2).	S3
4	A headline said "Foundation implemented" while the items said In Progress.	Headlines are generated from item statuses (§2).	S3
5	MFA was described as blocked, and consoles couldn't be opened.	MFA built in S1; one synthetic privileged demo account (§6).	S1
6	Backend work was claimed without a test report.	Every run reports command and counts; CI on each PR (§2, §26).	All
7	The role model differed between the brief and the code.	16 canonical roles from the first migration (§6).	S1
8	Resources lacked verifier and dates; entries were missing.	Resource metadata and full set (§10).	S3
9	Connector cards lacked source, date and planned label.	§9 rules.	S3
10	No architecture package.	Written in S0, before feature code (§19).	S0
11	No pricing model; a patient subscription would carry Canada Health Act risk.	§22.	S9
12	Code lived only inside a chat tool, on a preview host.	Repository and environments from S0 (§23).	S0
13	Unverified third-party plugins had access to the code.	Tooling register (§23.6).	S0
14	Credential statuses existed, but no verification method was defined.	Practitioner verification pipeline (§28).	S2

28. Practitioner identity and licence verification **NEW v2.1**

The aim is that nobody can act as a healthcare professional on CareBridge unless three things are true. They are who they say they are. A Saskatchewan regulator confirms they hold a current licence that covers what they will do. And a named CareBridge Credentialing Officer has checked the evidence. This section expands the provider-onboarding flow in §11.

Which standard applies. No single Canadian standard is written specifically for virtual-care platforms. CareBridge adopts **primary-source verification**, the practice used across healthcare credentialing: a credential is confirmed with the body that issued it (the regulatory college), never taken from the applicant's own documents alone. Facility credentialing guidance in Canada, such as the CPSA guide for accredited facilities, also checks licence and practice areas on the regulator's register, plus training evidence, references, regulatory declarations and a criminal record check, with reviews at defined intervals. Counsel and the Medical Director confirm the final policy.

28.1 Threats this must stop

Threat	Why a licence lookup alone doesn't stop it	Control
Invented practitioner	Caught by a register lookup.	Register lookup is mandatory (step 2).
Impersonating a real licensed person	The public register confirms that a name holds a licence, not that the applicant is that person. This is the most likely attack.	Identity proofing plus binding the person to the licence (steps 1 and 3).
Licence suspended, expired or under conditions	It may have been valid at onboarding and change later.	Ongoing monitoring and expiry-driven auto-restriction (§28.4).
Licensed only in another province	The licence is genuine but doesn't cover a patient in Saskatchewan.	Jurisdiction check (step 4).
Acting outside scope (e.g. an RN prescribing)	The licence is genuine but its scope is narrower.	Scope and conditions become ABAC attributes (step 5).
Unregulated practitioner presented as licensed	There's no regulator register to check.	Separate category, never labelled licensed; excluded from the pilot (§28.5).
Insider approving a friend or themselves	The process is followed but the reviewer is compromised.	Separation of duties and second review for exceptions (step 10).

28.2 Verification pipeline

Step	What is checked	Evidence stored	Pass rule
1. Identity proofing	Government photo ID plus a liveness check through a reviewed identity-verification vendor, or a live video check with the Credentialing Officer.	Vendor result and reference, method, date. ID images kept only as long as the retention policy allows.	Identity confirmed at the assurance level set in the credentialing policy.
2. Licence lookup (primary source)	The regulator's public register: name, registration number, profession and category, status, conditions, discipline notes, expiry date.	Timestamped capture (PDF or screenshot), register URL, who captured it, file hash.	Status is practising, with no suspension, and not expired.
3. Bind person to licence	At least one strong link between the proofed identity and the register entry: a Certificate of Professional Conduct or Standing sent by the regulator directly to CareBridge; confirmation through contact details held by the regulator or a verified employer; or a video interview comparing the ID with the licence details.	Method, document or record, reviewer.	The name on the ID matches the register entry, and at least one binding method succeeds.
4. Jurisdiction	The licence covers the province where the patient is at the time of care. Saskatchewan-only for the pilot.	Jurisdiction recorded on the credential.	Out-of-province licences are blocked unless the regulator's written rules and counsel allow it.
5. Scope and conditions	Profession, category, specialty, prescribing authority, supervision requirements, conditions on the licence.	Stored as structured attributes, each with its source.	The attributes drive ABAC: an action outside scope is denied.
6. Specialty (if claimed)	Specialist certification checked with the certifying body (e.g. Royal College or CFPC for physicians).	Capture and date.	No specialty is displayed without evidence.
7. Liability protection	Professional liability coverage appropriate to the profession (e.g. CMPA for physicians); confirm the requirement for each profession.	Certificate and expiry date.	Coverage current.
8. Organization affiliation	A verified organization administrator attests to the affiliation; the organization's legitimacy is checked (business registration and any required facility licence).	Attestation record, registry capture.	Both confirmed.
9. Background and declarations	Criminal record or vulnerable-sector check as the policy requires; self-declaration of complaints or proceedings in any jurisdiction.	Result, date, declaration version.	Per the policy; discrepancies escalate.
10. Human decision	The Credentialing Officer reviews everything. They can't approve themselves, someone in their own organization, or anyone they have a conflict with. Conditions, discrepancies and specialty claims go to a second reviewer (Medical Director).	Decision, reasons, reviewers, timestamps (audited).	Approval recorded by an authorized human; there is no automatic approval.

Step	What is checked	Evidence stored	Pass rule
11. Activation	Status becomes Verified, with an expiry date equal to the earliest of: licence expiry, liability expiry, and the re-verification interval.	Credential record.	Clinical access is granted only while Verified, and only through care relationships.

28.3 What patients see

The badge reads "CareBridge verified: licence confirmed with [regulator] on [date]", with a link to the regulator's public register. It never says "certified" or "endorsed", and it never appears without evidence. Profession and any specialty come from verified attributes, not from the practitioner's own profile text.

28.4 Ongoing monitoring

- Re-check the register before each licence expiry date, and on a fixed schedule in between (proposed: every 30 days, to be confirmed in the policy). Also re-check whenever a complaint or concern is raised.
- At the expiry timestamp, access is automatically set to Restricted, with no clinical actions until the licence is re-verified. Any register status other than practising sets the credential to Suspended immediately.
- When a practitioner is suspended, their open care relationships, appointments and tasks get handoff tasks, and affected patients are told to expect a new clinician, without stating the reason.
- If verification can't be performed (the register is down, the result is unclear), the system fails safe: no new clinical access is granted.
- Two accounts using the same registration number, or a mismatch between the ID name and the register name, block activation and are flagged for review.

28.5 Saskatchewan regulators for the pilot professions

These are the primary sources. Before building, confirm each register's URL and terms of use. The CRNS directory, for example, says its information may not be used for commercial purposes. Checks are therefore done by the Credentialing Officer and recorded as evidence. Don't scrape registers, and ask each regulator for written permission or a data-sharing arrangement before any systematic or automated checking.

Profession	Regulator	Public verification source
Physicians	College of Physicians and Surgeons of Saskatchewan (CPSS)	"Find a Physician" search, plus an advanced search for suspended, revoked or former licensees. Certificates of Professional Conduct available.
Registered nurses and nurse practitioners	College of Registered Nurses of Saskatchewan (CRNS)	Public directory showing status, conditions, disciplinary actions, NP designation, and effective and expiry dates. Not for commercial use without permission.
Pharmacists	Saskatchewan College of Pharmacy Professionals (SCPP)	"Find a Pharmacist" roster. Prescribing authority levels are defined by SCPP.
Physical therapists	Saskatchewan College of Physical Therapists (SCPT)	Public search (confirm URL at build time).
Psychologists	Saskatchewan College of Psychologists	Register (confirm URL at build time).

Profession	Regulator	Public verification source
Other regulated professions (LPNs, psychiatric nurses, social workers, dietitians, OTs)	Their Saskatchewan regulators	Add to the policy one profession at a time, only after its register is confirmed.
Counselling therapists and psychotherapists	Not regulated in Saskatchewan (CCPA, February 2024; confirm current status)	No licence to verify. Exclude from the pilot. If added later, use a separate category that's never described as licensed.

28.6 Data model

Tables: practitioner_identities (proofing result, method, assurance level, date), provider_credentials (statuses Unverified, Pending, Verified, Restricted, Suspended, Expired, with expiry), credential_attributes (profession, category, specialty, prescribing authority, conditions, each with a source), credential_evidence (type, source URL, captured_at, captured_by, file reference, hash), verification_decisions (reviewer, second reviewer, outcome, reasons), liability_coverage, affiliation_attestations and monitoring_schedule. Evidence files live in private object storage. Every read and write is audited, and only Credentialing Officers, Medical Directors and Auditors can read the evidence.

28.7 Required tests

- An Unverified, Pending, Restricted, Suspended or Expired practitioner can't offer slots, open a patient, message a patient or join a care relationship.
- At the licence expiry timestamp, access becomes Restricted without anyone taking action.
- A Credentialing Officer can't approve their own credential or one from their own organization.
- A condition on the licence blocks the matching action (e.g. no prescribing).
- A licence from another province is denied for a patient located in Saskatchewan.
- A duplicate registration number, or a name mismatch between ID and register, blocks activation.
- The verified badge renders only when an evidence record and an approval exist.
- Suspending a practitioner creates handoff tasks for all their open care.
- Demo and staging use synthetic regulators and synthetic registers only. No real lookups with test data.

28.8 Before onboarding real practitioners

Onboarding real practitioners means collecting their real personal information, even before any patient PHI exists. Before that starts, CareBridge needs:

- A written credentialing policy approved by the Medical Director.
- An appointed Credentialing Officer.
- A PIA entry for practitioner data.
- A vendor review of the identity-verification provider.
- Written permission from each regulator for how CareBridge uses its register.
- A retention rule for identity and evidence files.
- A practitioner privacy notice.

Appendix A. Sprint 0-2 prompts (paste one at a time) **NEW**

v2.1

Start a new, empty project in Astra/Codex for the build, not the prototype conversation. Upload this PDF to the project. Paste each prompt only after the previous one reports TESTED.

Sprint 0: project setup and architecture package

Sprint 0 - Project setup. Build CareBridge Canada FROM SCRATCH per the attached brief v2.1. The chatgpt.site prototype is design reference only; do not copy its code.

1. Propose the stack in docs/architecture/ADR-001.md (language, framework, DB, ORM, auth, hosting region in Canada, test runner). STOP and wait for my approval.
2. After approval: scaffold the app; create AGENTS.md (brief Appendix B), SECURITY.md, .gitignore, .env.example, CI (lint, typecheck, test), dependabot, PR template.
3. Environments: dev + staging config; PHI_PRODUCTION_ENABLED=false and PAYMENTS_ENABLED=false enforced server-side.
4. docs/architecture/: short files for all brief section 19 items, status Proposed. Prioritize Stage 0-2 items: data inventory, PHI data-flow register, schema draft, threat register, RBAC matrix (16 roles, incl. denied actions).
5. Push to private repo ericnosa/carebridge-canada (main). STOP before pushing and list files. Tests: CI runs green on an empty test suite plus one smoke test.

Return ONLY: COMPLETED / TESTED (command + pass/fail counts) / BLOCKED / NEXT (max 3).

Sprint 1: identity, tenancy, roles and audit

Sprint 1. Follow AGENTS.md and brief sections 5-7.

1. organizations, clinics, memberships; organization_id on every org-scoped table; server-side tenant enforcement (never from client input).
2. Identity: sign-up/sign-in, secure sessions, MFA (WebAuthn/passkey + TOTP + recovery codes), server-side recent-MFA check for privileged routes.
3. RBAC + ABAC for the 16 canonical roles (brief section 6), deny by default.
4. audit_events: append-only, fields per brief section 7; audit login, reads of sensitive data, writes, role changes, admin actions, denials.
5. Seed synthetic orgs/clinics/users; ONE labelled privileged demo account, dev only.

Tests: unauthenticated denied; Clinic A cannot read Clinic B; IDOR/BOLA; horizontal and vertical escalation; MFA-less privileged user denied; demo account denied outside dev; every sensitive action writes an audit event; audit rows cannot be updated or deleted.

Return ONLY: COMPLETED / TESTED (command + pass/fail counts) / BLOCKED / NEXT (max 3).

Sprint 2: practitioner verification, care relationships, consent

Sprint 2. Follow AGENTS.md and brief sections 6, 7, 11 and 28.

1. Practitioner verification pipeline per brief 28.2 with SYNTHETIC regulators and registers only (no real lookups): practitioner_identities, provider_credentials, credential_attributes, credential_evidence, verification_decisions, liability_coverage, affiliation_attestations, monitoring_schedule.
2. Credentialing Officer review queue: evidence view, approve/reject with reasons, second-review routing for conditions/discrepancies/specialty. No auto-approval.
3. Expiry-driven auto-Restricted; non-practising register status -> Suspended; suspension creates handoff tasks. Badge text per brief 28.3 only with evidence.
4. care_relationships (patient, provider, clinic, org, type, authority, dates, status), enforced in every patient-scoped query.
5. consent_records and processing_authorities as separate tables (brief section 7).

Tests: all brief 28.7 tests; patient-scoped query without care relationship denied; withdrawn consent blocks queued consent-dependent action.

Return ONLY: COMPLETED / TESTED (command + pass/fail counts) / BLOCKED / NEXT (max 3).

Appendix B. AGENTS.md (commit to the repository root)

NEW v2.0, UPDATED v2.1

```
# CareBridge Canada - standing rules for coding agents
Governing brief: docs/architecture/CareBridge-Canada-Astra-Master-Prompt-v2.1.pdf
This is a from-scratch build. The chatgpt.site prototype is design reference only.

- PHI_PRODUCTION_ENABLED=false and PAYMENTS_ENABLED=false, enforced server-side.
  Synthetic data only.
- Never add real patient data, real clinical messaging, real medical uploads, real clinical
  integrations, real regulator lookups, live checkout, or free trials.
- Deny by default. All authorization server-side. Never trust client-supplied tenant or role.
- Every organization-scoped resource has organization_id. Data-access changes need
  tenant-isolation tests (Clinic A cannot access Clinic B).
- Patient data access requires an active care_relationship or documented authority.
- Only practitioners with credential status Verified (brief section 28) get clinical access.
  Never auto-approve a credential. Never show a verified badge without evidence.
- Sensitive reads/writes/exports, role, consent, credential and billing changes write
  audit events.
- Emergency info (911, HealthLine 811, 9-8-8) and resources are never gated by login,
  onboarding, coverage, subscription, or payment.
- Never claim HIPA compliant, certified, clinically validated, penetration tested,
  government approved, or production ready.
- Status labels: Proposed, Implemented, Tested, Human Review Required, Approved, Blocked.
  Unbuilt UI functions show "Not implemented". Only a named human sets Approved.
- Roles: the 16 canonical roles in brief section 6.
- No new dependencies without reason, licence, and maintenance status.
- Do not rewrite working, tested code unless asked. No long docs.
- Never print secret values. STOP before pushes, shared-data migrations, or deletions.
- One sprint run = one branch = one PR; CI must pass.
- End every task with: COMPLETED / TESTED (command + pass/fail counts) / BLOCKED / NEXT (max 3).
```

Reference baseline for Astra to re-check **UPDATED v2.1**

These sources support the privacy assessment/audit, interoperability, accessibility, pricing-policy and emergency reference points, plus the practitioner-verification sources for §28. They don't validate this product, the availability of named integrations, or every proposed engineering control. Re-check current laws, standards, vendor capabilities, and applicable contracts at implementation time.

- Saskatchewan IPC, Privacy Impact Assessment Guidance Document:
<https://oipc.sk.ca/assets/privacy-impact-assessment-guidance-document.pdf>
- Saskatchewan IPC, Audit and Monitoring Guidelines for Trustees:
<https://oipc.sk.ca/resources/resource-directory/audit-and-monitoring-guidelines-for-trustees/>
- Canada Health Infoway, Pan-Canadian Patient Summary overview:
<https://accelero.infoway-inforoute.ca/en/initiatives/patient-summary>
- W3C, WCAG 2.2 Quick Reference:
<https://www.w3.org/WAI/WCAG22/quickref/>
- Health Canada, Canada Health Act Annual Report 2024–2025 (v2.0):
<https://www.canada.ca/en/health-canada/services/publications/health-system-services/canada-health-act-annual-report-2024-2025.html>
- College of Physicians and Surgeons of Saskatchewan, Policy: Uninsured Services (v2.0):
https://www.cps.sk.ca/imis/CPSS/CPSS/Legislation_ByLaws_Policies_and_Guidelines/Legislation_Content/Policies_and_Guidelines_Content/Uninsured_Services.aspx
- Saskatchewan Medical Association, Virtual Care (v2.0):
<https://www.sma.sk.ca/virtual-care/>
- Saskatchewan Health Authority, HealthLine 811 (v2.0):
<https://www.saskhealthauthority.ca/your-health/conditions-illnesses-services-wellness/healthline-8-1-1>

- 9-8-8 Suicide Crisis Helpline (v2.0; verify before publication):
<https://988.ca>
- OWASP, Authorization Cheat Sheet (v2.0):
https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
- OpenAI, Codex Security plugin quickstart (v2.0):
<https://developers.openai.com/codex/security/plugin>
- CPSS, Registration and physician search (v2.1):
https://www.cps.sk.ca/imis/cpss/registration/Registration_Overview.aspx?RegistrationCCO=Registration+Overview
- CPSS, Virtual Care licensure requirements (v2.1):
https://www.cps.sk.ca/imis/web/Applicants/Licensure/Virtual_Care.aspx
- CRNS, Nurse licence public directory (v2.1):
<https://crns.alinityapp.com/Client/PublicDirectory>
- SCPP, Find a Pharmacist (v2.1):
<https://saskpharm.ca/site/find-a-pharmacist>
- SCPT, Saskatchewan College of Physical Therapists (v2.1):
<https://www.scpt.org/>
- CCPA, Regulation in Saskatchewan (v2.1):
<https://www.ccpa-accp.ca/regulation-in-saskatchewan/>
- CPSA, Credentialing and Privileging Guide for Accredited Facilities (v2.1):
<https://cpsa.ca/wp-content/uploads/2023/05/Credentialing-and-Privileging-Guide-for-Accredited-Facilities.pdf>

End of master prompt.